

Secure Coding Review Report

CodeAlpha Cyber Security Internship - Task 3

1. Introduction

This report reviews a deliberately vulnerable Python login application. The goal is to identify security weaknesses, evaluate risks, and recommend secure coding practices.

2. Application Overview

The application authenticates users using usernames and passwords stored directly in source code. Several intentional vulnerabilities were included to demonstrate common security issues.

3. Vulnerability Findings

3.1 Hardcoded Credentials (High)

Username and passwords are stored directly in the source code.

3.2 Plain Text Password Storage (High)

Passwords are stored and compared in plain text rather than using secure hashing.

3.3 Username Enumeration (Medium)

The system reveals whether a username exists, assisting attackers.

3.4 Sensitive Information Disclosure (High)

The application displays the user's password after login.

3.5 Unlimited Login Attempts (Medium)

Attackers can repeatedly guess passwords without restriction.

3.6 Weak Password Policy (Medium)

Weak passwords such as 'password123' are allowed.

3.7 No Audit Logging (Medium)

Failed login attempts are not recorded for investigation.

3.8 Poor Privilege Management (Medium)

Administrative access is granted based solely on username.

4. Risk Assessment

High Risk: - Hardcoded Credentials - Plain Text Password Storage - Sensitive Information Disclosure
Medium Risk: - Username Enumeration - Unlimited Login Attempts - Weak Password Policy - No Audit Logging - Poor Privilege Management

5. Recommendations

- Use bcrypt for password hashing.
- Store credentials securely in databases.
- Implement account lockout policies.
- Enforce strong password requirements.
- Remove sensitive information from output.
- Implement logging and monitoring.
- Use proper role-based access control.

6. Conclusion

The reviewed application contains several common security weaknesses. Implementing the recommended controls significantly improves confidentiality, integrity, and system security.